

2-GoBuster

Gobuster es una herramienta ofensiva de código abierto escrita en Golang. Enumera directorios web, subdominios DNS, vhosts, buckets de Amazon S3 y Google Cloud Storage mediante fuerza bruta, utilizando listas de palabras específicas y gestionando las respuestas entrantes. Muchos profesionales de seguridad utilizan esta herramienta para pruebas de penetración, búsqueda de recompensas por errores y evaluaciones de ciberseguridad. Al analizar las fases del hacking ético, podemos ubicar a Gobuster entre las fases de reconocimiento y escaneo.

Antes de explorar Gobuster, analicemos brevemente los conceptos de enumeración y fuerza bruta.

Enumeración

La enumeración es el acto de listar todos los recursos disponibles, sean accesibles o no. Por ejemplo, Gobuster enumera directorios web.

Fuerza bruta

La fuerza bruta es el acto de probar todas las posibilidades hasta encontrar una coincidencia. Es como tener diez llaves y probarlas todas en una cerradura hasta que una encaje. Gobuster utiliza listas de palabras para este propósito.

Gobuster: Resumen

Gobuster se incluye por defecto en distribuciones como Kali Linux. Para empezar, consultemos la página de ayuda de Gobuster. Esta página ofrece una buena descripción general de sus funcionalidades y opciones.

Introduzca el siguiente comando: gobuster --help. Debería acceder a la página de ayuda de Gobuster, como se muestra a continuación:

```
root@tryhackme:~# gobuster --help
Usage:
  gobuster [command]

Available Commands:
  completion  Generate the autocompletion script for the specified shell
  dir         Uses directory/file enumeration mode
  dns         Uses DNS subdomain enumeration mode
  fuzz        Uses fuzzing mode. Replaces the keyword FUZZ in the URL, Headers and the request body
  gcs         Uses gcs bucket enumeration mode
  help        Help about any command
  s3          Uses aws bucket enumeration mode
  tftp        Uses TFTP enumeration mode
  version     shows the current version
  vhost       Uses VHOST enumeration mode (you most probably want to use the IP address as the URL parameter)

Flags:
  --debug           Enable debug output
  --delay duration  Time each thread waits between requests (e.g. 1500ms)
  -h, --help        help for gobuster
  --no-color        Disable color output
  --no-error        Don't display errors
  -z, --no-progress Don't display progress
  -o, --output string Output file to write results to (defaults to stdout)
  -p, --pattern string File containing replacement patterns
  -q, --quiet        Don't print the banner and other noise
  -t, --threads int  Number of concurrent threads (default 10)
  -v, --verbose      Verbose output (errors)
  -w, --wordlist string Path to the wordlist. Set to - to use STDIN.
  --wordlist-offset int Resume from a given position in the wordlist (defaults to 0)

Use "gobuster [command] --help" for more information about a command.
```

La página de ayuda contiene varias secciones:

Uso: Muestra la sintaxis del comando.

Comandos disponibles: Disponemos de varios comandos para enumerar directorios, archivos, subdominios DNS, buckets de Google Cloud Storage y buckets de Amazon AWS S3. En esta sala, nos centraremos en los comandos dir, dns y vhost. Los abordaremos en las siguientes tareas.

Marcas: Son opciones específicas que podemos configurar para personalizar nuestros comandos. Veamos las marcas que usaremos con frecuencia en esta sala:

Short Flag	Long Flag	Description
-t	-- threads	Esta marca configura el número de subprocesos que se utilizarán para el análisis. Cada uno de estos subprocesos envía solicitudes con un ligero retraso. El número predeterminado de subprocesos es 10. Este número puede ser lento al utilizar listas de palabras extensas. Puede aumentar o disminuir el número de subprocesos según los recursos disponibles del sistema.
-w	-- wordlist	Esta marca configura una lista de palabras para la iteración. Cada entrada de la lista de palabras se adjunta a la URL que incluyó en el comando.
	--delay	Este indicador define el tiempo de espera entre el envío de solicitudes. Algunos servidores web incluyen mecanismos para detectar la enumeración observando cuántas solicitudes se reciben en un período determinado. Podemos aumentar el retraso entre solicitudes posteriores para que parezca tráfico web normal.
	--debug	Este indicador nos ayuda a solucionar problemas cuando nuestro comando genera errores inesperados.
-o	--output	Este indicador escribe los resultados de la enumeración en el archivo que elijamos.

Ejemplo

Veamos un ejemplo de cómo usaríamos estos comandos e indicadores juntos para enumerar un directorio web:

```
gobuster dir -u "http://www.example.thm/" -w /usr/share/wordlists/dirb/small.txt -t 64
```

- gobuster dir indica que usaremos el modo de enumeración de directorios y archivos.
- -u "http://www.example.thm/" indica a Gobuster que la URL de destino es <http://example.thm/>.
- -w /usr/share/wordlists/dirb/small.txt indica a Gobuster que use la lista de palabras small.txt para acceder por fuerza bruta a los directorios web. Gobuster usará cada entrada de la lista de palabras para crear una nueva URL y enviará una solicitud GET a dicha URL. Si la primera entrada de la lista de palabras fueran imágenes, Gobuster enviaría una solicitud GET a <http://example.thm/images/>.
- -t 64 establece el número de subprocesos que Gobuster usará en 64. Esto mejora drásticamente el rendimiento.

Ahora que tenemos una visión general de Gobuster, exploremos los diferentes modos y sus casos de uso en las siguientes tareas.

Answer the questions below

What flag do we use to specify the target URL?

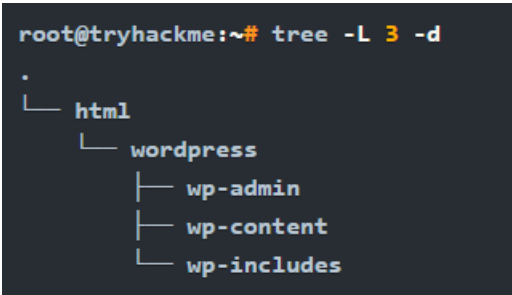
Respuesta: -u

What **command** do we use for the subdomain enumeration mode?

Respuesta: dns

Caso de uso: Enumeración de directorios y archivos

Gobuster cuenta con un modo dir, que permite a los usuarios enumerar los directorios de sitios web y sus archivos. Este modo es útil al realizar una prueba de penetración y desear ver la estructura de directorios de un sitio web y qué archivos contiene. A menudo, las estructuras de directorios de sitios web y aplicaciones web siguen una convención específica, lo que las hace susceptibles a ataques de fuerza bruta mediante listas de palabras. Por ejemplo, la estructura de directorios en el servidor web que aloja WordPress se ve así:



Gobuster es potente porque permite escanear el sitio web y devolver los códigos de estado. Estos códigos indican inmediatamente si, como usuario externo, se puede solicitar ese directorio.

Help

Si desea obtener una descripción completa de lo que ofrece el comando dir de Gobuster, puede consultar la página de ayuda. Ver la extensa página de ayuda del comando dir puede resultar un poco intimidante. Por lo tanto, nos centraremos en las opciones más importantes. Escriba el siguiente comando para mostrar la ayuda: gobuster dir --help.

Se utilizan muchas opciones para ajustar el comando gobuster dir. No es posible repasarlas todas, pero en la tabla a continuación, se enumeran las opciones que cubren la mayoría de los escenarios:

Flag	Long Flag	Description
-c	--cookies	Esta bandera configura una cookie para pasar cada solicitud, como un ID de sesión.
-x	--extensions	Esta opción especifica las extensiones de archivo que se desean escanear. Por ejemplo, .php, .js
-H	--headers	Esta opción configura un encabezado completo para que se transmita con cada solicitud.
-k	--no-tls-validation	Esta opción omite el proceso de verificación del certificado cuando se usa https. Esto suele ocurrir en eventos CTF o salas de prueba, como las de THM, cuando se usa un certificado autofirmado. Esto provoca un error durante la verificación TLS.
-n	--no-status	Puede configurar esta opción si no desea ver los códigos de estado de cada respuesta recibida. Esto ayuda a mantener la salida en pantalla clara.
-P	password	Puede configurar esta opción junto con la opción --username para ejecutar solicitudes autenticadas. Esto es útil cuando se han obtenido las credenciales de un usuario.
-s	--status-codes	Con esta bandera, puede configurar qué códigos de estado de las respuestas recibidas desea mostrar, como 200, o un rango como 300-400.
-b	--status-codes-blacklist	Este indicador le permite configurar los códigos de estado de las respuestas recibidas que no desea mostrar. Configurar este indicador anula el indicador -s.
-U	--username	Puede configurar este indicador junto con el indicador --password para ejecutar solicitudes autenticadas. Esto es útil cuando ha obtenido las credenciales de un usuario.
-r	--followredirect	Este indicador configura Gobuster para seguir la redirección que recibió como respuesta a la solicitud enviada. Se utiliza un código de estado de redirección HTTP (por ejemplo, 301 o 302) para redirigir al cliente a una URL diferente.

Cómo usar el modo dir

Para ejecutar Gobuster en modo dir, utilice el siguiente formato de comando:

```
gobuster dir -u "http://www.example.thm" -w /path/to/wordlist
```

Observe que el comando también incluye los indicadores -u y -w, además de la palabra clave dir. Estos dos indicadores son necesarios para que la enumeración de directorios de Gobuster funcione. Veamos un ejemplo práctico de cómo enumerar directorios y archivos con el modo dir de Gobuster:

```
gobuster dir -u "http://www.example.thm" -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -r
```

Este comando escanea todos los directorios ubicados en www.example.thm utilizando la lista de palabras directory-list-2.3-medium.txt. Analicemos con más detalle cada parte del comando:

- gobuster dir : Configura Gobuster para usar el modo de enumeración de directorios y archivos.
- -u http://www.example.thm :
 - La URL será la ruta base donde Gobuster comenzará a buscar. Por lo tanto, la URL anterior utiliza el directorio web raíz. Por ejemplo, en una instalación típica de Apache en Linux, este es /var/www/html. Si tiene un directorio "resources" y desea enumerarlo, debe configurar la URL como <http://www.example.thm/resources>. También puede considerarlo como <http://www.example.thm/path/to/folder>.
 - La URL debe contener el protocolo utilizado, en este caso, HTTP. Esto es importante y obligatorio. Si se utiliza un protocolo incorrecto, el escaneo fallará.
 - En la parte del host de la URL, puede ingresar la IP o el nombre del host. Sin embargo, es importante mencionar que al usar la IP, podría dirigirse a un sitio web diferente al previsto. Un servidor web puede alojar varios sitios web con una sola IP (esta técnica también se denomina alojamiento virtual). Use el NOMBRE DE HOST para estar seguro.
- Gobuster no enumera recursivamente. Por lo tanto, si los resultados muestran una ruta de directorio que le interesa, deberá enumerar ese directorio específico.
- -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt :configura Gobuster para usar la lista de palabras directory-list-2.3-medium.txt para enumerar. Cada entrada de la lista de palabras se añade a la URL configurada.
- -r :configura Gobuster para seguir las respuestas de redirección recibidas de las solicitudes enviadas. Si se recibió un código de estado 301, Gobuster navegará a la URL de redirección incluida en la respuesta.

Veamos un segundo ejemplo donde usamos la opción -x para especificar el tipo de archivos que queremos enumerar:

```
gobuster dir -u "http://www.example.thm" -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .php,.js
```

Este comando buscará directorios ubicados en <http://example.thm> usando la lista de palabras directory-list-2.3-medium.txt. Además de listar directorios, este comando también lista todos los archivos con extensión .php o .js.

Answer the questions below

Which flag do we have to add to our command to skip the TLS verification? Enter the long flag notation.

--no-tls-validation

Enumerate the directories of www.offensivetools.thm. Which directory catches your attention?

```
root@ip-10-201-12-75:~# sudo nano /etc/resolv-dnsmasq
root@ip-10-201-12-75:~# /etc/init.d/dnsmasq restart
Restarting dnsmasq (via systemctl): dnsmasq.serviceJob for dnsmasq.service failed because the control process exited with error code.
See "systemctl status dnsmasq.service" and "journalctl -xe" for details.

root@ip-10-201-12-75:~# cat /etc/resolv-dnsmasq
nameserver 10.201.6.20
nameserver 169.254.169.253
root@ip-10-201-12-75:~# sudo nano /etc/hosts
root@ip-10-201-12-75:~# cat /etc/hosts
127.0.0.1      localhost
127.0.0.1      vnc.tryhackme.tech
127.0.1.1      tryhackme.lan  tryhackme
10.201.6.20    www.offensivetools.thm

# The following lines are desirable for IPv6 capable hosts
::1           localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
root@ip-10-201-12-75:~#
```

se tiene que agregar la ip a /etc/hosts y a /etc/resolv-dnsmasq, si no, no funciona la maquina.

se usa el siguiente comado gobuster dir -u "http://www.offensivetools.thm" -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

```
root@ip-10-201-12-75:~# gobuster dir -u "http://www.offensivetools.thm" -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://www.offensivetools.thm
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/images (Status: 301) [Size: 333]
/home (Status: 200) [Size: 8818]
/media (Status: 301) [Size: 332]
/templates (Status: 301) [Size: 336]
/modules (Status: 301) [Size: 334]
/plugins (Status: 301) [Size: 334]
/includes (Status: 301) [Size: 335]
/language (Status: 301) [Size: 335]
/components (Status: 301) [Size: 337]
/api (Status: 301) [Size: 330]
/cache (Status: 301) [Size: 332]
/libraries (Status: 403) [Size: 287]
/tmp (Status: 301) [Size: 330]
/layouts (Status: 301) [Size: 334]
/secret (Status: 301) [Size: 333]
/administrator (Status: 301) [Size: 340]
Progress: 13123 / 218276 (6.01%)
```

la respuetas es el archivo secret

Continue enumerating the directory found in question 2. You will find an interesting file there with a .js extension. What is the flag found in this file?

ejecutamoe el comando

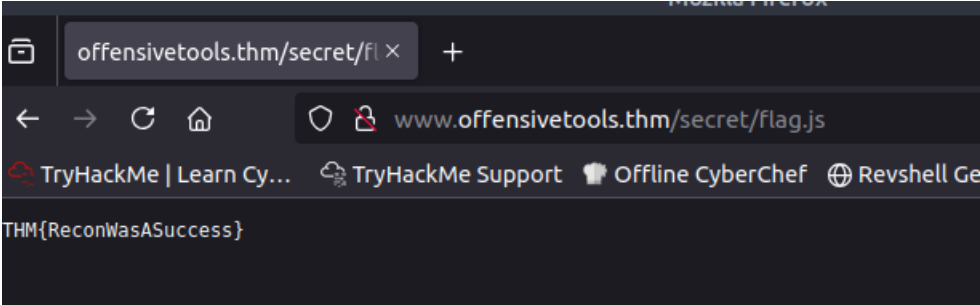
```
gobuster dir -u "http://www.offensivetools.thm/secret" -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 64 -x .js
```

```
root@ip-10-201-12-75:~# gobuster dir -u "http://www.offensivetools.thm/secret" -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 64 -x .js
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://www.offensivetools.thm/secret
[+] Method: GET
[+] Threads: 64
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: js
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/content (Status: 301) [Size: 341]
=====
/uploads (Status: 301) [Size: 341]
=====
Progress: 688 / 436552 (0.16%) Get "http://www.offensivetools.thm/secret/home": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
Get "http://www.offensivetools.thm/secret/09": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
Get "http://www.offensivetools.thm/secret/default.js": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
/flag.js (Status: 200) [Size: 22]
Progress: 5250 / 436552 (1.20%)
```

```
gobuster dir -u "http://www.offensivetools.thm/secret/flag.js" -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 64 -x .js
```

```
root@ip-10-201-12-75:~# gobuster dir -u "http://www.offensivetools.thm/secret/flag.js" -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 64 -x .js
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://www.offensivetools.thm/secret/flag.js
[+] Method: GET
[+] Threads: 64
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: js
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
Progress: 436550 / 436552 (100.00%)
=====
Finished
```

abrimos el navegador y navegamos a la url que obtuvimos



respuesta
THM{ReconWasASuccess}

Caso de uso: Enumeración de subdominios

El siguiente modo en el que nos centraremos es el modo DNS. Este modo permite a Gobuster realizar ataques de fuerza bruta contra subdominios. Durante una prueba de penetración, es fundamental verificar los subdominios del dominio principal del objetivo. Que un elemento esté parcheado en el dominio normal no significa que también lo esté en el subdominio. Podría existir una oportunidad para explotar una vulnerabilidad en uno de estos subdominios. Por ejemplo, si TryHackMe posee tryhackme.thm y mobile.tryhackme.thm, podría haber una vulnerabilidad en mobile.tryhackme.thm que no esté presente en tryhackme.thm. ¡Por eso es importante buscar también subdominios!

Help

Si desea obtener una descripción completa de lo que ofrece el comando DNS de Gobuster, puede consultar la página de ayuda. Consultar la extensa página de ayuda del comando DNS puede resultar intimidante. Nos centraremos en las banderas más importantes de esta sala. Escriba el siguiente comando para mostrar la ayuda: `gobuster dns --help`

El modo dns ofrece menos banderas que el modo dir. Sin embargo, estas son más que suficientes para cubrir la mayoría de los escenarios de enumeración de subdominios DNS. Veamos algunas de las banderas más utilizadas:

Flag	Long Flag	Description
-c	--show-cname	Mostrar registros CNAME (no se puede usar con el indicador -i).
-i	--show-ips	Al incluir este indicador, se muestran las direcciones IP a las que se resuelven el dominio y los subdominios.
-r	--resolver	Este indicador configura un servidor DNS personalizado para la resolución.
-d	--domain	Este indicador configura el dominio que desea enumerar.

Cómo usar el modo DNS Para ejecutar Gobuster en modo DNS, utilice la siguiente sintaxis de comando:

```
gobuster dns -d example.thm -w /path/to/wordlist
```

Observe que el comando también incluye los indicadores -d y -w, además de la palabra clave dns. Estos dos indicadores son necesarios para que la enumeración de subdominios de Gobuster funcione. Veamos un ejemplo de cómo enumerar subdominios con el modo DNS de Gobuster:

```
gobuster dns -d example.thm -w /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
```

- gobuster dns enumera los subdominios del dominio configurado.
- -d example.thm establece el destino en el dominio example.thm.
- -w /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt establece la lista de palabras como subdomains-top1million-5000.txt. Gobuster utiliza cada entrada de esta lista para construir una nueva consulta DNS. Si la primera entrada de esta lista es 'all', la consulta sería all.example.thm.

Escriba el comando usted mismo. Debería obtener el siguiente resultado:

```
root@tryhackme:~# gobuster dns -d example.thm -w /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Domain:      example.thm
[+] Threads:     10
[+] Timeout:     1s
[+] Wordlist:     /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
=====
Starting gobuster in DNS enumeration mode
=====
Found: www.example.thm

Found: shop.example.thm

Found: academy.example.thm

Found: primary.example.thm

Progress: 4989 / 4990 (99.98%)
=====
Finished
=====
```

Answer the questions below

Apart from the dns keyword and the -w flag, which **shorthand flag** is required for the command to work?

respuesta -d

Use the commands learned in this task, how many subdomains are configured for the offensivetools.thm domain?

respuesta 4

ejecutamos el comando

```
gobuster dns -d offensivetools.thm -w /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
```

```
root@ip-10-201-12-75:~# gobuster dns -d offensivetools.thm -w /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Domain:      offensivetools.thm
[+] Threads:     10
[+] Timeout:     1s
[+] Wordlist:     /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
=====
Starting gobuster in DNS enumeration mode
=====
[INFO] [-] Unable to validate base domain: offensivetools.thm (lookup offensivetools.thm on 127.0.0.53:53: no such host)
Found: www.offensivetools.thm

Found: WWW.offensivetools.thm

Progress: 4997 / 4998 (99.98%)
=====
Finished
=====
root@ip-10-201-12-75:~#
```

Caso de uso: Enumeración de vhost

El último modo en el que nos centraremos es el vhost. Este modo permite a Gobuster realizar ataques de fuerza bruta contra hosts virtuales. Los hosts virtuales son sitios web diferentes en la misma máquina. A veces, parecen subdominios, ¡pero no se deje engañar! Los hosts virtuales se basan en IP y se ejecutan en el mismo servidor. Los subdominios se configuran en DNS. La diferencia entre el vhost y el dns radica en la forma en que Gobuster escanea:

- El modo vhost navega a la URL creada al combinar el HOSTNAME configurado (indicador -u) con una entrada de una lista de palabras.
- El modo dns realiza una búsqueda DNS al FQDN(**fully qualified domain name**) creado al combinar el nombre de dominio configurado (indicador -d) con una entrada de una lista de palabras.

Help

Si desea obtener una descripción completa de lo que ofrece el comando vhost de Gobuster, puede consultar la página de ayuda. Consultar la extensa página de ayuda del comando vhost puede resultar intimidante. Nos centraremos en las banderas más importantes de esta sala. Escriba el siguiente comando para mostrar la ayuda: gobuster vhost --help

El modo vhost ofrece banderas similares a las del modo dir. Veamos algunas de las banderas más utilizadas:

Short Flag	Long Flag	Description
-u	--url	Especifica la URL base (dominio de destino) para la fuerza bruta de nombres de host virtuales.
	--append-domain	Añade el dominio base a cada palabra de la lista de palabras (p. ej., palabra.ejemplo.com).
-m	--method	Especifica el método HTTP que se utilizará para las solicitudes (p. ej., GET, POST).
	--domain	Añade un dominio a cada entrada de la lista de palabras para formar un nombre de host válido (útil si no se proporciona explícitamente).
	--exclude-length	Excluye resultados según la longitud del cuerpo de la respuesta (útil para filtrar respuestas no deseadas).
-r	--follow-redirect	Sigue redirecciones HTTP (útil para casos en los que los subdominios pueden redirigir).

Cómo usar el modo vhost

Para ejecutar Gobuster en modo vhost, escriba el siguiente comando:

```
gobuster vhost -u "http://example.thm" -w /path/to/wordlist
```

Observe que el comando también incluye los indicadores -u y -w, además de la palabra clave vhost. Estos dos indicadores son necesarios para que la enumeración de vhost de Gobuster funcione. Veamos un ejemplo práctico de cómo enumerar hosts virtuales con el modo vhost de Gobuster:

```
root@tryhackme:~# gobuster vhost -u "http://10.201.6.20" --domain example.thm -w /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt --append-domain --exclude-length 250-320
```

```
root@tryhackme:~# gobuster vhost -u "http://10.201.6.20" --domain example.thm -w /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt --append-domain --exclude-length 250-320
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:          http://10.10.94.214
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
[+] User Agent:    gobuster/3.6
[+] Timeout:      10s
[+] Append Domain: true
[+] Exclude Length: 250,254,263,274,283,293,294,299,253,261,269,277,285,290,300,257,258,270,278,282,291,252,260,264,268,271,279,280,289,
=====
Starting gobuster in VHOST enumeration mode
=====
Found: blog.example.thm Status: 200 [Size: 1493]
Found: shop.example.thm Status: 200 [Size: 2983]
Found: www.example.thm Status: 200 [Size: 84352]
Found: chelyabinsk-rnoc-rr02.backbone.example.thm Status: 404 [Size: 304]
Found: academy.example.thm Status: 200 [Size: 434]
Progress: 4989 / 4990 (99.98%)
=====
Finished
=====
```

Notarás que este comando es mucho más complejo que la sintaxis básica. Contiene muchos más indicadores configurados. Esto suele ocurrir en pruebas reales, dependiendo de cómo se haya configurado la infraestructura del dominio a probar. En nuestro caso, no tenemos una infraestructura DNS completamente configurada. Esto requiere que proporcionemos indicadores adicionales como --domain y --append-domain. Necesitamos analizar las solicitudes web que envía Gobuster para comprender mejor su funcionamiento. A continuación, puedes ver una solicitud GET básica a www.example.thm:

```
GET / HTTP/1.1
Host: www.example.thm
User-Agent: gobuster/3.6
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
```

Gobuster enviará múltiples solicitudes, cambiando cada vez la parte "Host:" de la solicitud. El valor de "Host:" en este ejemplo es www.example.thm. Podemos dividirlo en tres partes:

- www : Este es el subdominio. Esta es la parte que Gobuster completará con cada entrada de la lista de palabras configurada.
- .example : Este es el dominio de segundo nivel. Puede configurarlo con el indicador --domain (debe configurarse junto con el dominio de nivel superior).
- .thm : Este es el dominio de nivel superior. Puede configurarlo con el indicador --domain (debe configurarse junto con el dominio de nivel superior).

Ahora que sabemos cómo Gobuster envía su solicitud, analicemos el comando y examinemos cada indicador más de cerca:

- gobuster vhost le indica a Gobuster que enumere los hosts virtuales.
- -u "http://10.201.6.20" establece la URL de navegación en 10.201.6.20.
- -w /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt configura Gobuster para usar la lista de palabras subdomains-top1million-5000.txt. Gobuster añade cada entrada de la lista de palabras al dominio configurado. Si no se configura ningún dominio explícitamente con el indicador --domain , Gobuster lo extraerá de la URL. Por ejemplo, test.example.thm, help.example.thm, etc. Si se encuentra algún subdominio, Gobuster lo informará en la

terminal.

- `--domain example.thm` asigna los dominios de nivel superior y secundario en la sección "Nombre de host:" de la solicitud a `example.thm`.
- `--append-domain` añade el dominio configurado a cada entrada de la lista de palabras. Si no se configura este parámetro, el nombre de host establecido será `www`, `blog`, etc. Esto provocará que el comando funcione incorrectamente y muestre falsos positivos.
- `--exclude-length` filtra las respuestas de las solicitudes web enviadas. Con este parámetro, podemos filtrar los falsos positivos. Si ejecuta el comando sin este parámetro, observará que obtendrá muchos falsos positivos como "Encontrado: Orion.example.thm Estado: 404 [Tamaño: 279]" o "Encontrado: pm.example.thm Estado: 404 [Tamaño: 276]". Estos falsos positivos suelen tener un tamaño de respuesta similar, por lo que podemos usar esto para filtrar la mayoría de los falsos positivos. Esperamos obtener una respuesta de 200 OK para obtener un verdadero positivo. Hay, sin embargo, excepciones, pero no es competencia de esta sala profundizar en ellas.

Answer the questions below

Use the commands learned in this task to answer the following question: How many vhosts on the `offensivetools.thm` domain reply with a status code 200?

respuesta: 4

```
gobuster vhost -u "http://10.201.6.20" --domain offensivetools.thm -w /usr/share/wordlists/SecLists/Discovery/DNS/subdomains-top1million-5000.txt --append-domain --exclude-length 250-320
```

Conclusión

En esta sala, aprendimos sobre la herramienta ofensiva Gobuster. Esta herramienta enumera directorios, archivos, subdominios DNS y hosts virtuales.

Hemos cubierto tres modos diferentes de la herramienta Gobuster:

Modo DNS: enumera subdominios DNS.

Modo dir: enumera directorios.

Modo vhost: enumera hosts virtuales.

Para cada modo, cubrimos las opciones de configuración necesarias y las opciones adicionales que optimizan los resultados deseados.

Hemos destacado la diferencia entre hosts virtuales y subdominios, y la forma en que Gobuster los busca:

El modo DNS utiliza los servicios DNS para buscar subdominios utilizando el dominio y la lista de palabras configurados.

El modo vhost envía solicitudes web utilizando la URL y la lista de palabras configuradas.

Al final de cada tarea, aplicamos directamente las habilidades aprendidas mediante ejercicios prácticos.